

UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ

Actividad 04

Una página demasiado convincente

Magdalena Yesenia Tristán Rivera — Matrícula 174702

Carrera: Ingeniería en Tecnologías de la Información (ITI)

CNO IV – Programación WAP · Grupo T37A

Profesor: Servando López Contreras

31 de agosto de 2026

Tabla de índice

- Objetivo de la actividad
- Descripción del escenario
- Configuración del laboratorio
- Evidencias y descripción del funcionamiento
- Explicación del flujo de captura de información
- Controles de seguridad propuestos
- Conclusión
- Referencias

Objetivo de la actividad

El objetivo de esta actividad es implementar y analizar, en un entorno de laboratorio controlado, una simulación de ingeniería social mediante la herramienta Social-Engineer Toolkit (SET), utilizando una página web ficticia para comprender el funcionamiento de una técnica de captura de información y reconocer los elementos que permiten identificar un intento de phishing.

De forma específica, se busca configurar un escenario básico de ingeniería social con SET, implementar una página web ficticia mediante el módulo Credential Harvester, analizar cómo se transmite y registra la información introducida en un formulario, identificar indicadores técnicos y visuales que permiten reconocer una página potencialmente fraudulenta, y proponer controles de seguridad orientados a prevenir o reducir el impacto de ataques de phishing.

Descripción del escenario

El escenario simula el área de seguridad informática de una organización que ha recibido varios reportes de empleados que aseguran haber recibido un mensaje relacionado con una supuesta actualización de sus credenciales de inicio de sesión. El mensaje contiene un enlace que dirige a un portal aparentemente institucional.

Para esta actividad se desarrolló una página ficticia de autenticación correspondiente a un sistema inventado, llamado Portal Académico UNITEC-LAB. La página incluye logotipo, campos de usuario y contraseña, un botón de inicio de sesión y un mensaje indicando que la sesión ha expirado y se necesita iniciar sesión nuevamente.

A primera vista, nada parece fuera de lo común. Sin embargo, el portal no pertenece a ninguna organización real: fue construido específicamente para este laboratorio, se ejecuta únicamente dentro de la propia computadora (127.0.0.1) y en ningún momento se utilizaron dominios, credenciales o servidores reales.

Configuración del laboratorio

El ataque se simuló utilizando Kali Linux ejecutado mediante WSL2 (Windows Subsystem for Linux) sobre Windows. Esta instancia cumple simultáneamente el papel de atacante — al correr Social-Engineer Toolkit y levantar el servidor web falso con Credential Harvester — y de víctima, ya que el navegador que "cae" en la página falsa se abre en la misma computadora y accede a través de 127.0.0.1 (localhost). Esto reproduce exactamente el mismo entorno aislado y controlado que pide la actividad, sin exponer nada hacia redes externas.

Los pasos de preparación fueron los siguientes:

1. Instalación de Social-Engineer Toolkit (SET) y del servidor Apache dentro de Kali Linux (paquete set).
2. Creación de la página ficticia (index.html) del Portal Académico UNITEC-LAB, con nombre del sistema, campos de usuario y contraseña, botón de ingreso y mensaje de sesión expirada.
3. Verificación de que la página se renderiza correctamente antes de iniciar el ataque.
4. Inicio de SET (sudo setoolkit) y navegación hasta el módulo Credential Harvester Attack Method, usando la opción Custom Import — en vez de Site Cloner — para no clonar ningún portal real, tal como lo exige la actividad.
5. Configuración de la IP de POST-back en 127.0.0.1, para que toda la información capturada se quede dentro de la misma máquina.

```

kali@kali:~/mnt/c:/WINDOWS/system32$
<input type="password" name="password" placeholder="Contraseña" required>
<button type="submit">Ingresar</button>
</form>
<div class="foot">© UNITEC-LAB - Sistema de autenticación institucional</div>
</div>
</body>
</html>
</pre>

kali@kali:~/mnt/c:/WINDOWS/system32$
$ cat ~/actividad04/portal/index.html
<!DOCTYPE html>
<html lang="es">
<head>
<meta charset="UTF-8">
<title>UNITEC-LAB - Portal Académico</title>
<style>
body{font-family:Arial,sans-serif;background:#eef1f5;display:flex;
align-items:center;justify-content:center;height:100vh;margin:0;}
.card{background:#fff;padding:40px;border-radius:10px;width:340px;
box-shadow:4px 4px 0px rgba(0,0,0,12);text-align:center;}
.logo{font-weight:700;font-size:20px;color:#1f4e79;margin-bottom:4px;}
.sub{font-size:12px;color:#6b7f85;margin-bottom:10px;letter-spacing:.04em;text-transform:uppercase;}
.warn{background:#fdecece;border-radius:10px;padding:10px 12px;
border-radius:6px;margin-bottom:10px;text-align:left;}
input{width:100%;padding:10px 12px;margin-bottom:12px;border:1px solid #c6d3db;
border-radius:6px;box-sizing:border-box;font-size:14px;}
button{width:100%;padding:11px;background:#1f4e79;color:#fff;border:none;
border-radius:6px;font-size:14px;cursor:pointer;}
.foot{margin-top:10px;font-size:11px;color:#9a9ab1;}
</style>
</head>
<body>
<div class="card">
<div class="logo">UNITEC-LAB</div>
<div class="sub">Portal Académico</div>
<div class="warn">Su sesión ha expirado. Inicie sesión nuevamente para continuar.</div>
<form method="POST" action="#">
<input type="text" name="username" placeholder="Usuario Institucional" required>
<input type="password" name="password" placeholder="Contraseña" required>
<button type="submit">Ingresar</button>
</form>
<div class="foot">© UNITEC-LAB - Sistema de autenticación institucional</div>
</div>
</body>
</html>

kali@kali:~/mnt/c:/WINDOWS/system32$

```

Figura 1. Código fuente completo de la página ficticia (index.html) verificado antes de iniciar el ataque.

Evidencias y descripción del funcionamiento

A continuación se documenta, paso a paso, la ejecución completa de la práctica dentro de Kali Linux.

1. Inicio de SET

```

kali@kali:~/mnt/c/WINDOWS/system32$
<div class="logo">UNITEC-LAB</div>
<div class="sub">Portal Académico</div>
<div class="warn">Su sesión ha expirado. Inicie sesión nuevamente para continuar.</div>
<form method="POST" action="">
  <input type="text" name="username" placeholder="Usuario institucional" required>
  <input type="password" name="password" placeholder="Contraseña" required>
  <button type="submit">Ingresar</button>
</form>
<div class="foot">© UNITEC-LAB - Sistema de autenticación institucional</div>
</div>
</body>
</html>

kali@kali:~/mnt/c/WINDOWS/system32$
$ sudo setoolkit
[sudo] password for kali:
[*] New set.config.py file generated on: 2026-08-31 18:08:10.169686
[*] Verifying configuration update...
[*] Update verified, config timestamp is: 2026-08-31 18:08:10.169686
[*] SET is using the new config, no need to restart
Copyright 2020, The Social-Engineer Toolkit (SET) by TrustedSec, LLC
All rights reserved.

Redistribution and use in source and binary forms, with or without modification, are permitted provided that the following conditions are met:

  * Redistributions of source code must retain the above copyright notice, this list of conditions and the following disclaimer.
  * Redistributions in binary form must reproduce the above copyright notice, this list of conditions and the following disclaimer in the documentation and/or other materials provided with the distribution.
  * Neither the name of Social-Engineer Toolkit nor the names of its contributors may be used to endorse or promote products derived from this software without specific prior written permission.

THIS SOFTWARE IS PROVIDED BY THE COPYRIGHT HOLDERS AND CONTRIBUTORS "AS IS" AND ANY EXPRESS OR IMPLIED WARRANTIES, INCLUDING, BUT NOT LIMITED TO, THE IMPLIED WARRANTIES OF MERCHANTABILITY AND FITNESS FOR A PARTICULAR PURPOSE ARE DISCLAIMED. IN NO EVENT SHALL THE COPYRIGHT OWNER OR CONTRIBUTORS BE LIABLE FOR ANY DIRECT, INDIRECT, INCIDENTAL, SPECIAL, EXEMPLARY, OR CONSEQUENTIAL DAMAGES (INCLUDING, BUT NOT LIMITED TO, PROCUREMENT OF SUBSTITUTE GOODS OR SERVICES; LOSS OF USE, DATA, OR PROFITS; OR BUSINESS INTERRUPTION) HOWEVER CAUSED AND ON ANY THEORY OF LIABILITY, WHETHER IN CONTRACT, STRICT LIABILITY, OR TORT (INCLUDING NEGLIGENCE OR OTHERWISE) ARISING IN ANY WAY OUT OF THE USE OF THIS SOFTWARE, EVEN IF ADVISED OF THE POSSIBILITY OF SUCH DAMAGE.

The above licensing was taken from the BSD licensing and is applied to Social-Engineer Toolkit as well.

Note that the Social-Engineer Toolkit is provided as is, and is a royalty free open-source application.

Feel free to modify, use, change, market, do whatever you want with it as long as you give the appropriate credit where credit is due (which means giving the authors the credit they deserve for writing it).

Also note that by using this software, if you ever see the creator of SET in a bar, you should (optional) give him a hug and should (optional) buy him a beer (or bourbon - hopefully bourbon). Author has the option to refuse the hug (most likely will never happen) or the beer or bourbon (also most likely will never happen). Also by using this tool (these are all optional of course!), you should try to make this industry better, try to stay positive, try to help others, try to learn from one another, try stay out of drama, try offer free hugs when possible (and make sure recipient agrees to mutual hug), and try to do everything the Social-Engineer Toolkit is designed purely for good and not evil. If you are planning on using this tool for malicious purposes that are not authorized by the company you are performing assessments for, you are violating the terms of service and license of this toolset. By hitting yes (only one time), you agree to the terms of service and that you will only use this tool for lawful purposes only.

Do you agree to the terms of service [y/n]:

```

Figura 2. Arranque de setoolkit y aceptación de los términos de uso del programa.

[illegible]

Figura 3. Menú principal de SET, listo para seleccionar Social-Engineering Attacks.

2. Selección del vector de ataque

```
set> 2
The Web Attack module is a unique way of utilizing multiple web-based attacks in order to compromise the intended victim.
The Java Applet Attack method will spoof a Java Certificate and deliver a Metasploit-based payload. Uses a customized java applet created by Thomas Werth to deliver the payload.
The Metasploit Browser Exploit method will utilize select Metasploit browser exploits through an iframe and deliver a Metasploit payload.
The Credential Harvester method will utilize web cloning of a web- site that has a username and password field and harvest all the information posted to the website.
The Tabnabbing method will wait for a user to move to a different tab, then refresh the page to something different.
The Web-Jacking Attack method was introduced by white_sheep, emgent. This method utilizes iframe replacements to make the highlighted URL link to appear legitimate however when clicked a window pops up then is replaced with the malicious link. You can edit the link replacement settings in the set_config if it's too slow/fast.
The Multi-Attack method will add a combination of attacks through the web attack menu. For example, you can utilize the Java Applet, Metasploit Browser, Credential Harvester/Tabnabbing all at once to see which is successful.
The HTA Attack method will allow you to clone a site and perform PowerShell injection through HTA files which can be used for Windows-based PowerShell exploitation through the browser.

1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method

99) Return to Main Menu

set:webattack>
```

Figura 4. Menú de Website Attack Vectors, con la opción Credential Harvester Attack Method disponible.

```
set:webattack>3

The first method will allow SET to import a list of pre-defined web applications that it can utilize within the attack.

The second method will completely clone a website of your choosing and allow you to utilize the attack vectors within the completely same web application you were attempting to clone.

The third method allows you to import your own website, note that you should only have an index.html when using the import website functionality.

1) Web Templates
2) Site Cloner
3) Custom Import

99) Return to Webattack Menu

set:webattack>
```

Figura 5. Submenú de Credential Harvester: se eligió Custom Import para usar la página propia, sin clonar sitios reales.

3. Configuración del Harvester

```
set:webattack> IP address for the POST back in Harvester/Tabnabbing [172.30.101.195]: 127.0.0.1
[!] Example: /home/website/ (make sure you end with /)
[!] Also note that there MUST be an index.html in the folder you point to.
set:webattack> Path to the website to be cloned: /home/kali/actividad04/portal/index.html
[-] Example: http://www.blah.com
set:webattack> URL of the website you imported:
```

Figura 6. Configuración de la IP de POST-back (127.0.0.1) y la ruta al archivo index.html del Portal Académico UNITEC-LAB.

```
set:webattack> IP address for the POST back in Harvester/Tabnabbing [172.30.101.195]: 127.0.0.1
[!] Example: /home/website/ (make sure you end with /)
[!] Also note that there MUST be an index.html in the folder you point to.
set:webattack> Path to the website to be cloned: /home/kali/actividad04/portal/index.html
[-] Example: http://www.blah.com
set:webattack> URL of the website you imported: http://portal-academico.unitec-lab.local

The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
```

Figura 7. Confirmación de que el Credential Harvester quedó activo y escuchando en el puerto 80.

4. Simulación de la víctima

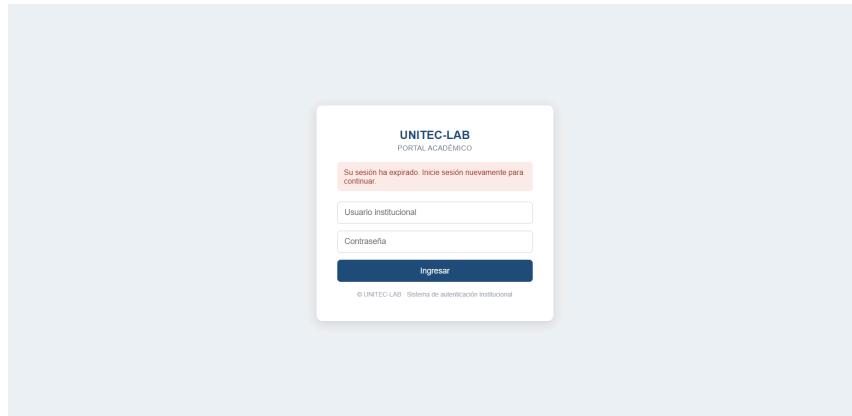


Figura 8. Portal Académico UNITEC-LAB renderizado en el navegador (<http://localhost>), listo para recibir credenciales de prueba.

```

The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
127.0.0.1 - - [31/Aug/2026 18:14:00] "GET / HTTP/1.1" 200 -
127.0.0.1 - - [31/Aug/2026 18:14:00] "GET /favicon.ico HTTP/1.1" 404 -
[*] WE GOT A HIT! Printing the output:
POSSIBLE USERNAME FIELD FOUND: username=alumno.prueba
POSSIBLE PASSWORD FIELD FOUND: password=Prueba#2026
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.

```

Figura 9. Credential Harvester capturando en tiempo real las credenciales de prueba enviadas ("WE GOT A HIT!").

5. Reporte generado

```

(kali@Magi)-[/mnt/c/WINDOWS/system32]
$ sudo ls -la /root/.set/reports/
total 16
drwxr-xr-x 3 root root 4096 Aug 31 18:18 .
drwxr-xr-x 4 root root 4096 Aug 31 18:21 ..
-rw-r--r-- 1 root root 216 Aug 31 18:18 '2026-08-31 18:18:55.880635.xml'
drwxr-xr-x 2 root root 4096 Aug 31 18:18 files

(kali@Magi)-[/mnt/c/WINDOWS/system32]
$

```

Figura 10. Carpeta de reportes de SET (/root/.set/reports/) con el archivo XML generado tras finalizar la captura.

```

(kali@Magi)-[/mnt/c/WINDOWS/system32]
$ sudo cat "/root/.set/reports/2026-08-31 18:18:55.880635.xml"
<?xml version="1.0" encoding='UTF-8'?>
<harvester>
  URL=http://portal-academico.unitec-lab.local
  <url>      <param>username=alumno.prueba</param>
            <param>password=Prueba#2026</param>
  </url>
</harvester>

```

Figura 11. Contenido del reporte XML: URL de origen y credenciales (username / password) capturadas en texto plano.

Explicación del flujo de captura de información

El recorrido completo de la información, desde que la víctima recibe el enlace hasta que el atacante cuenta con sus credenciales, sigue esta secuencia:

1. La víctima recibe un mensaje (correo, SMS o chat) con un enlace que aparenta dirigir al portal institucional.
2. Al hacer clic, su navegador solicita la página al servidor del atacante — en este laboratorio, Apache sirviendo en 127.0.0.1:80.
3. SET entrega la página ficticia (Portal Académico UNITEC-LAB), que imita visualmente un inicio de sesión legítimo.
4. La víctima introduce usuario y contraseña y presiona "Ingresar"; el formulario envía una petición HTTP POST con los parámetros username y password.
5. El proceso Credential Harvester de SET intercepta esa petición POST, extrae los parámetros y los registra en el reporte (visible en pantalla como "WE GOT A HIT!").
6. El navegador de la víctima es redirigido, reduciendo la sospecha de que algo salió mal.
7. El atacante consulta el reporte generado (/root/.set/reports/*.xml) y ya cuenta con credenciales que podría intentar usar contra el sistema real.

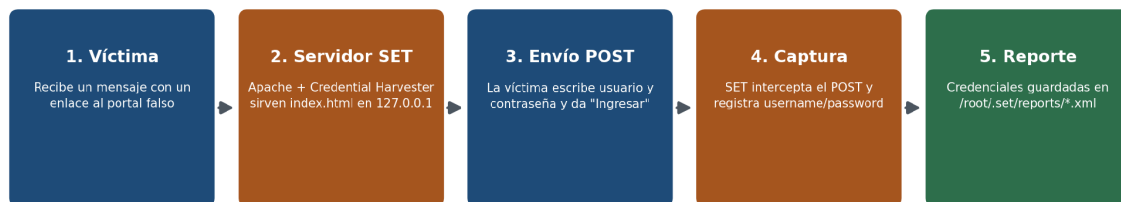


Figura 12. Diagrama del flujo de la simulación de phishing ejecutada en el laboratorio.

Diferencia entre captura de credenciales y vulneración de una contraseña

Aunque suelen confundirse, son dos ataques distintos. La captura de credenciales — lo realizado en esta práctica — es un ataque de ingeniería social: la víctima entrega voluntariamente su usuario y contraseña reales a una página falsa, engañada por el contexto (urgencia, apariencia institucional). No se rompe ningún mecanismo criptográfico ni se adivina nada; el atacante obtiene la contraseña porque la propia víctima la escribió.

Vulnerar una contraseña, en cambio, es un ataque técnico dirigido contra el mecanismo de autenticación: fuerza bruta, ataques de diccionario, o explotar hashes almacenados de forma débil, todo ello sin que la víctima participe ni tenga conocimiento del intento. Por eso los controles que mitigan cada uno son distintos: contra la captura de credenciales sirven la capacitación y la verificación de la fuente; contra la vulneración de contraseñas sirven políticas de contraseñas robustas, bloqueo por intentos fallidos y almacenamiento seguro de hashes.

Controles de seguridad propuestos

Indicadores de phishing identificados

A partir del propio Portal Académico UNITEC-LAB construido en el laboratorio, se identificaron los siguientes indicadores que permiten reconocer una página de phishing:

Indicador observado	Por qué delata phishing
URL basada en una IP o "localhost" en vez de un dominio institucional	Un portal legítimo usa su propio dominio registrado (por ejemplo unitec.edu.mx); nunca una IP directa.
Ausencia de HTTPS / candado en el navegador	Un sistema real que solicita contraseñas cifra el tráfico con TLS; el laboratorio sirvió la página por HTTP plano.
Mensaje de urgencia ("su sesión ha expirado, inicie sesión nuevamente")	Técnica clásica de ingeniería social: presiona a actuar rápido, sin verificar, generando ansiedad.
Diseño genérico o ligeramente distinto al portal real de la institución	Las páginas fraudulentas construidas rápido suelen tener inconsistencias visuales, tipografías o logotipos de baja calidad.
El formulario no lleva a un panel funcional tras enviarse	Los sitios de captura de credenciales no tienen backend real: solo capturan y redirigen a otra parte.
Origen del enlace inesperado (correo, QR o mensaje no solicitado)	El vector de entrada nunca es un acceso habitual guardado por el usuario, sino un enlace que llegó por sorpresa.

Controles de seguridad propuestos

Para cada control se incluye su justificación y, siguiendo el criterio de evaluación, su alcance real y sus limitaciones:

Control	Justificación	Alcances y limitaciones
Autenticación multifactor (MFA)	Aunque la contraseña se filtre, el atacante no puede completar el acceso sin el segundo factor.	Alcance: neutraliza el uso aislado de una contraseña robada. Limitación: no protege contra phishing en tiempo real tipo adversary-in-the-middle, que también intercepta el código o el token de sesión.
Filtrado de correo / anti-phishing (SPF, DKIM, DMARC)	Bloquea o marca mensajes que suplantán el dominio institucional antes de llegar al usuario.	Alcance: reduce mensajes falsificados que lleguen por correo. Limitación: no cubre otros canales (SMS, WhatsApp, redes sociales) ni dominios "look-alike" no contemplados en las políticas.
Capacitación continua en concientización de phishing	El eslabón más débil suele ser humano; simulacros periódicos entrenan a detectar señales como las de la tabla anterior.	Alcance: mejora la capacidad de detección del personal. Limitación: su efectividad decae con el tiempo si no se refuerza, y no elimina por completo el error humano.
Verificación de certificados y extensiones anti-phishing en el navegador	Alertan automáticamente sobre certificados inválidos o dominios de registro muy reciente.	Alcance: detecta configuraciones técnicas sospechosas. Limitación: un atacante puede obtener certificados SSL válidos y gratuitos para su dominio falso, evadiendo esta señal.
Monitoreo de dominios similares (typosquatting) y reporte a un CSIRT	Permite dar de baja páginas falsas antes de que capturen credenciales de forma masiva.	Alcance: reduce el tiempo de vida de campañas activas. Limitación: depende de la velocidad de respuesta del proveedor o registrador; el daño puede ocurrir antes del retiro del sitio.

Conclusión

Esta práctica permitió comprobar, de forma directa y controlada, qué tan poco esfuerzo técnico requiere una campaña de phishing efectiva: bastó una página HTML sencilla, un servidor web y un módulo de captura para obtener credenciales en texto plano en cuanto la víctima confió en la apariencia del sitio. El punto débil no estuvo en ningún cifrado roto ni en ninguna vulnerabilidad de software, sino en la confianza depositada en una interfaz visualmente convincente.

Esto confirma que la defensa contra el phishing no puede depender de un solo control: se necesita una combinación de medidas técnicas (MFA, filtrado de correo, verificación de certificados) y medidas humanas (capacitación y hábito de verificar antes de introducir credenciales), ya que cada control por sí solo tiene límites claros, como se documentó en la tabla de controles. Reconocer los indicadores de una página falsa —URL, ausencia de HTTPS, mensajes de urgencia, inconsistencias visuales— es una habilidad tan importante como cualquier control técnico, porque suele ser la última barrera antes de que la información llegue al atacante.

Referencias

TrustedSec. (2024). *Social-Engineer Toolkit (SET)*. GitHub.

<https://github.com/trustedsec/social-engineer-toolkit>

MITRE ATT&CK. *T1566 – Phishing*. <https://attack.mitre.org/techniques/T1566/>

MITRE ATT&CK. *T1566.002 – Phishing: Spearphishing Link*.

<https://attack.mitre.org/techniques/T1566/002/>

OWASP Foundation. *Phishing* — guías de concientización y prevención. <https://owasp.org/>

Kali Linux Documentation. *Kali Linux on WSL2*. <https://www.kali.org/docs/wsl/>